

# Enhanced Attack Report

## AUTHENTIC ANTICS

*Generated on 2025-10-11*

## **Disclaimer**

This report has been generated automatically and should be used for informational purposes only. To generate this report, Large Language Models (LLMs) were used to analyze the provided data. This technology is not perfect and may generate incorrect or misleading results. The results should be reviewed by a human expert before taking any action based on the information provided.

## Definitions

**Pre-Conditions:** Conditions that must be true to execute the attack steps in the milestone.

**Post-Conditions:** Traces that an attacker leaves behind after executing the attack steps in the milestone.

**Attack Steps:** Steps that an attacker would take to achieve the goal of the milestone.

**MITRE Technique:** Techniques from the MITRE ATT&CK; framework that are relevant to the milestone.

## STIX

**Malware Name:** AUTHENTIC ANTICS

**Malware Description:** • AUTHENTIC ANTICS runs within the Outlook process, displaying malicious login prompts to steal credentials and OAuth 2.0 tokens which can be used to later access victim email accounts. • Extensive defence evasion techniques are employed by AUTHENTIC ANTICS such as environmental keying and removing suspected hooks from within ntdll.dll. • One of the malware stages masquerades as the Microsoft Authentication Library (MSAL) for .NET – available on GitHub – and includes the codebase for it, with classes added to implement malicious functionality. The included MSAL code is not used. • Network communications made by the malware are exclusively with legitimate services. • Victim data is exfiltrated by sending emails from the victim's account to an actor-controlled email address. The emails will not show in the victim's sent folder.

## Quick Overview

### Milestone m1

a1. Event Triggered Execution: Component Object Model Hijacking as used by the malware (T1546.015)

### Milestone m2

- a2. Deobfuscate/Decode Files or Information as used by the malware (T1140)
- a3. Impair Defenses: Disable or Modify Tools as used by the malware (T1112)
- a4. Execution Guardrails: Environmental Keying as used by the malware (T1480.001)
- a5. System Binary Proxy Execution as used by the malware (T1218.002)

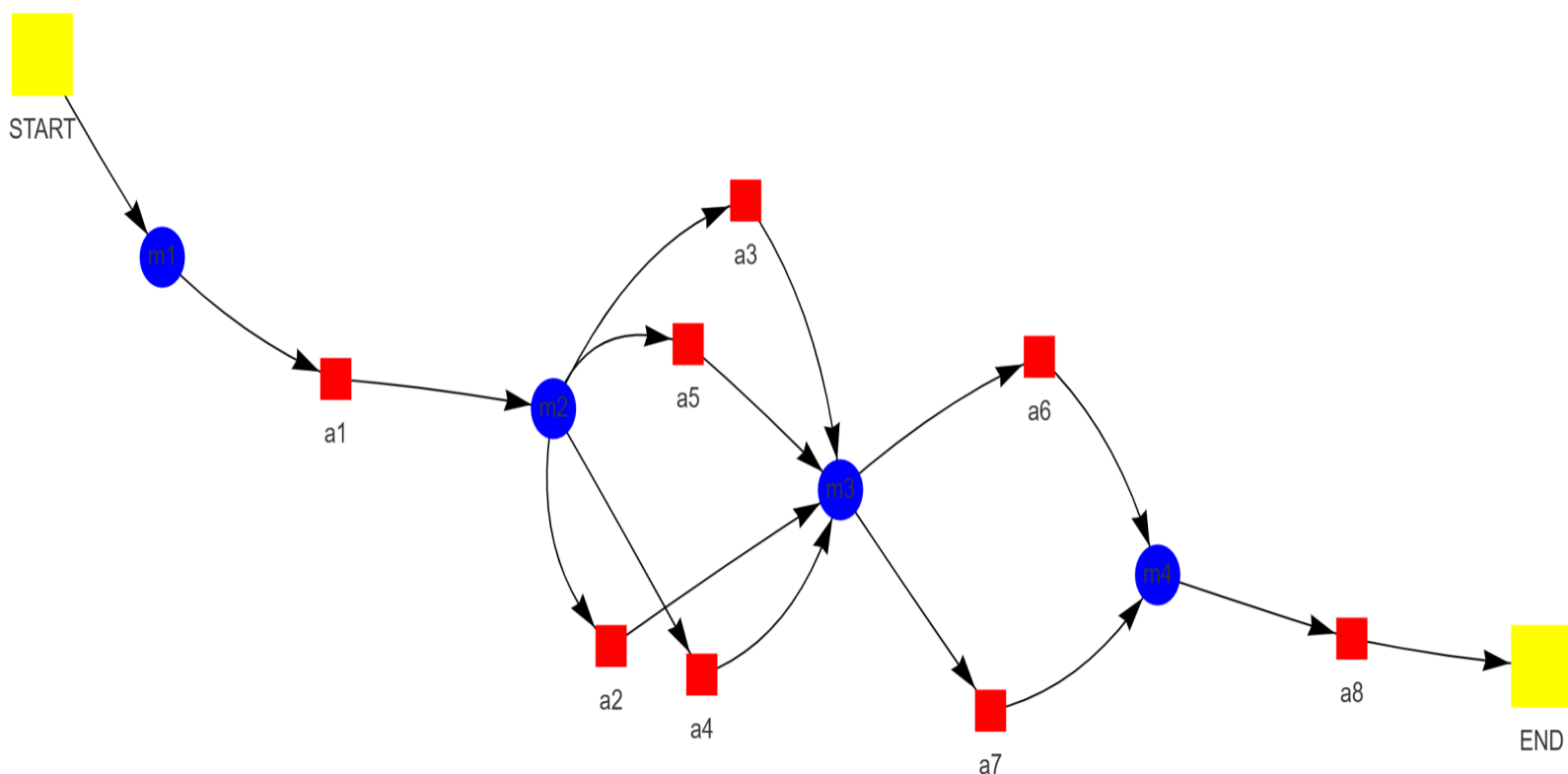
### Milestone m3

- a6. Adversary-in-the-Middle as used by the malware (T1528)
- a7. Forced Authentication as used by the malware (T1187)

### Milestone m4

- a8. Exfiltration Over Web Service as used by the malware (T1567)

## Attack Graph



## Milestone *m1*

### Attack Step *a1*

=====

**Name:** Event Triggered Execution: Component Object Model Hijacking as used by the malware

**Description:** Component Object Model (COM) hijacking is employed by the malware "Authentic Antics" for persistence purposes, classified as Event Triggered Execution. Target identification involves the malware pinpointing legitimate COM objects or services exhibiting frequent execution within the victim's system. These objects typically handle common tasks and are trusted by the operating system. The hijacking mechanism entails modifications to registry entries associated with the selected COM object. The original path to the legitimate executable is replaced with malicious code by the malware. Upon user interaction triggering the targeted COM object, the hijacked entry is executed instead of the original program. This effectively launches the malware disguised as a legitimate process. Stealthy execution is achieved as the malware operates under the guise of a trusted system component, hindering detection by security software and users. Persistent infection is facilitated as long as the hijacked COM object remains in regular use, enabling sustained access and control over the victim's system. Mitigation strategies include: implementation of regular security updates to mitigate vulnerabilities exploited for COM hijacking; meticulous registry monitoring to identify suspicious modifications introduced by malware; and deployment of robust anti-malware solutions with real-time protection capabilities to detect and remove malicious code, including those utilizing COM hijacking techniques.

## Pre-Conditions:

- A vulnerable system running a compatible operating system is present.
- A target system with a susceptible Component Object Model (COM) implementation exists.
- The malware has successfully infiltrated the target system.
- The malware possesses the necessary code to exploit vulnerabilities within the COM framework.

## Post-Conditions:

- Compromised email accounts
- Registry entries indicating malware installation and execution
- Altered system event logs
- Stolen credentials
- Gzipped and RSA-encrypted data files containing stolen information
- Network traffic logs showing communication with the C2 server
- Modified user profiles with added permissions for malicious processes
- Potential for further malicious activity
- Exfiltrated sensitive data
- Modified Outlook configuration files
- Presence of AUTHENTIC ANTICS malware code in memory or on disk
- Unusual API activity related to Microsoft authentication protocols

## ***MITRE Technique***

**ID:** T1546.015

**Name:** Event triggered execution: component object model hijacking

**Description:** Adversaries may establish persistence by executing malicious content triggered by hijacked references to Component Object Model (COM) objects. COM is a system within Windows to enable interaction between software components through the operating system. References to various COM objects are stored in the Registry.

**More info:** <https://attack.mitre.org/techniques/T1546/015>

# Milestone *m2*

## Attack Step *a2*

=====

**Name:** Deobfuscate/Decode Files or Information as used by the malware

**Description:** The malware utilizes a multi-layered approach to obfuscate files and information. Payload encryption is achieved through a method dependent on machine-specific identifiers such as the computer's GUID or volume serial number, enabling decryption solely on the designated target system. Exfiltration data undergoes compression employing the Gzip algorithm to minimize its size and reduce detectability during transmission. Furthermore, RSA encryption is implemented to safeguard exfiltrated data, ensuring decryption is possible only with the corresponding private key held by the attacker. These combined techniques contribute to the obfuscation of both the malware's core functionality and the stolen sensitive data, thereby increasing the difficulty of detection and analysis.

### Pre-Conditions:

- Access to the obfuscated files or information is available.
- Knowledge of common obfuscation techniques used by malware.
- A system capable of executing code and handling file operations.

### Post-Conditions:

- Reputational damage
- New log entries indicating suspicious activity
- Data theft
- DNS requests to unknown domains
- Loss of sensitive information
- System instability
- Network disruption
- Compromised user accounts
- Network traffic logs showing communication with malicious servers
- Hidden files or folders containing stolen data
- Unusual process activity in system logs
- Altered system files
- Presence of malware executables and artifacts
- Modified registry entries

### ***MITRE Technique***

**ID:** T1140

**Name:** Deobfuscate/decode files or information

**Description:** Adversaries may use Obfuscated Files or Information to hide artifacts of an intrusion from analysis. They may require separate mechanisms to decode or deobfuscate that information depending on how they intend to use it. Methods for doing that include built-in functionality of malware or by using utilities present on the system.

**More info:** <https://attack.mitre.org/techniques/T1140/>

## Attack Step *a3*

=====

**Name:** Impair Defenses: Disable or Modify Tools as used by the malware

**Description:** Registry API unhooking is a technique involving the modification of Windows' handling of calls to functions within the ntdll.dll library. This library facilitates interactions with the Windows registry, a database storing system and application settings. Malware, such as "Authentic Antics," injects code into running processes on the victim's machine. This injected code intercepts calls made by legitimate applications to ntdll.dll functions pertaining to registry access. Through modification of these intercepted calls, malware can prevent detection by security software and bypass implemented security measures. Registry API unhooking is a sophisticated technique that enables malware operation with a high degree of stealth due to its targeting of core system functions and potential to disable essential security mechanisms.

### Pre-Conditions:

- The target system has security tools installed.
- The malware must have knowledge of the target system's security tools and their configurations.

### Post-Conditions:

- Compromised Microsoft 365 accounts
- Malicious login windows displayed to victims
- Logs of intercepted credentials and OAuth tokens
- Exfiltrated victim data via emails sent from compromised accounts
- Modified registry keys in  
HKLM\SOFTWARE\Classes\CLSID{1299CF18-C4F5-4B6A-BB0F-2299F0398E27}\InprocServer32
- Modified Outlook process behavior
- Presence of malware modules within the system
- Emails sent from compromised accounts to actor-controlled addresses
- Stolen credentials and OAuth tokens
- Persistent endpoint access to Microsoft cloud accounts for the attackers
- Network connections between victim machines and actor-controlled servers

### MITRE Technique

**ID:** T1112

**Name:** Modify registry

**Description:** Adversaries may interact with the Windows Registry as part of a variety of other techniques to aid in defense evasion, persistence, and execution.

**More info:** <https://attack.mitre.org/techniques/T1112/>

### Attack Step a4

=====

**Name:** Execution Guardrails: Environmental Keying as used by the malware

**Description:** Environmental keying is a technique employed by malware to encrypt its payload utilizing data specific to the victim's system environment. This data may encompass elements such as the machine GUID, network interface card (NIC) MAC address, system time, and hard drive serial number. Within the context of the Authentic Antics malware, environmental key derivation involves the extraction of one or more of these environmental factors from an infected system. Subsequently, a specific algorithm is utilized to transform this data into a unique encryption key. The malware's core code is then encrypted using this generated key, rendering it decryptable only on systems possessing the identical

environmental factors used in key creation. The effectiveness of environmental keying stems from its ability to evade traditional defense mechanisms. Antivirus and security software commonly rely on signature-based detection, which identifies known malware patterns. However, the unique nature of the encrypted payload, tailored to each victim's system, renders it unlikely to be flagged as malicious by standard defenses. Furthermore, the persistence of the malware is facilitated by the key's association with the victim's environment, enabling its continued operation even after system reboots or restorations.

## Pre-Conditions:

- The malware is running within the Outlook process.
- A Windows operating system is present.
- The malware has successfully infected a target system and gained execution privileges.
- The malware has the capability to analyze and compare code within memory.
- The malware has access to the ntdll.dll file.

## Post-Conditions:

- Compromised email accounts
- New user accounts created
- Loss of sensitive information
- Exfiltrated data files
- Unusual network traffic logs
- Potential spread to other systems within the environment
- Altered system files
- Suspicious email activity logs
- Modified registry keys
- Malware remnants in memory or disk space
- Damage to reputation and trust

## MITRE Technique

**ID:** T1480.001

**Name:** Execution guardrails: environmental keying

**Description:** Adversaries may environmentally key payloads or other features of malware to evade defenses and constrain execution to a specific target environment. Environmental keying uses cryptography to constrain execution or actions based on adversary supplied environment specific conditions that are expected to be present on the target. Environmental keying is an implementation of Execution Guardrails that utilizes cryptographic techniques for deriving encryption/decryption keys from specific types of values in a given computing environment.

**More info:** <https://attack.mitre.org/techniques/T1480/001>

## Attack Step a5

=====

**Name:** System Binary Proxy Execution as used by the malware

**Description:** System Binary Proxy Execution is employed by the Authentic Antics malware for evasion of detection and establishment of persistence within compromised systems. Process context hijacking is executed by the malware, which meticulously verifies its execution environment to ensure operation exclusively within the legitimate Outlook process. This enables Authentic Antics to leverage the trust and privileges associated with the Outlook application. Code injection and execution are then

performed once within the Outlook process. Authentic Antics injects malicious code into existing system functions or threads, leveraging this hijacked context for payload execution without raising suspicion from security tools primarily focused on analyzing standalone processes. Obfuscated communication techniques, such as string encryption and dynamic code loading, are likely utilized by Authentic Antics to further obfuscate activities when communicating with command-and-control servers or performing other malicious actions. This hinders the tracking of the malware's communication patterns and intentions by analysts. The effectiveness of System Binary Proxy Execution stems from its ability to evade detection by security software reliant on signature-based analysis or heuristics focused on suspicious processes. Persistence is ensured by leveraging the Outlook process, maintaining malware activity even during user logoff or system restarts as long as Outlook remains operational. Potential privilege escalation may occur if the compromised Outlook account possesses elevated privileges, granting Authentic Antics access to sensitive data and organizational systems. Mitigation strategies include robust process monitoring tools that analyze process behavior, including code injection attempts and suspicious communication patterns. Application whitelisting can restrict application execution to a predefined list of trusted software, preventing malicious code from running in unexpected contexts. Regular security updates for all software, including Outlook, are crucial to mitigate known vulnerabilities exploitable by malware such as Authentic Antics.

## **Pre-Conditions:**

- Network connectivity is available to establish communication with a proxy server.
- The malware has successfully executed on the compromised system.
- A compromised system is available.

## **Post-Conditions:**

- Exfiltration of sensitive data from compromised systems.
- Log files showing suspicious network activity, including connections to command-and-control servers.
- Traces of obfuscated code within compromised processes.
- Exfiltrated data files transferred to external servers.
- Altered system configurations indicating malware presence.
- Damage to the reputation and trust of affected organizations.
- Potential for further malicious activity on compromised systems.
- Compromised user accounts with stolen credentials and tokens.
- Modified registry keys containing stolen credentials and tokens.
- Network traffic analysis revealing communication patterns with malicious actors.

## ***MITRE Technique***

**ID:** T1218.002

**Name:** System binary proxy execution: control panel

**Description:** Adversaries may abuse control.exe to proxy execution of malicious payloads. The Windows Control Panel process binary (control.exe) handles execution of Control Panel items, which are utilities that allow users to view and adjust computer settings.

**More info:** <https://attack.mitre.org/techniques/T1218/002>

# Milestone *m3*

## Attack Step *a6*

=====

**Name:** Adversary-in-the-Middle as used by the malware

**Description:** The malware designated as "Authentic Antics," attributed to Russia's GRU, utilizes an Adversary-in-the-Middle (MitM) attack technique for the purpose of exfiltrating user credentials and OAuth 2.0 authorization codes from Microsoft 365 users. Initial compromise of a victim system is typically achieved through phishing emails or exploitation of vulnerabilities. Subsequent interception of network traffic directed towards Microsoft's OAuth 2.0 Authorization Server occurs once malware has gained access to the system. This server is responsible for user authentication and application authorization on behalf of the user. During user login attempts or application authorization requests, Authentic Antics captures the authorization code generated by the server. This code functions as a temporary token granting access to the user's account. Concurrently, the malware extracts the user's credentials (username and password) during the login process. The stolen authorization codes and credentials are subsequently encrypted and exfiltrated from the victim system via the victim's Outlook account. This method of communication utilizes legitimate Microsoft services, thereby evading detection by conventional network monitoring tools. The inherent danger of this technique stems from several factors: Persistence is facilitated by the stolen OAuth 2.0 authorization code, enabling the attacker to maintain continuous access to the victim's account even after removal of the initial malware infection. A single compromised account can potentially grant access to a wide spectrum of sensitive data and applications within an organization. The utilization of legitimate Microsoft services for communication renders malicious activity difficult to detect. To mitigate these risks, organizations must implement robust security measures: Multi-Factor Authentication (MFA) should be enforced for all user accounts, particularly those with access to sensitive data. Comprehensive network monitoring tools, including Intrusion Detection Systems (IDS), should be deployed to detect anomalous traffic patterns and potential MitM attacks. Security awareness training programs should educate users about phishing scams and the importance of strong passwords. Regular software updates, encompassing Microsoft 365 applications, are essential to patch known vulnerabilities. Understanding the tactics employed by sophisticated malware such as Authentic Antics enables organizations to take proactive steps in mitigating the risks posed by these advanced cyber threats.

## Pre-Conditions:

- A target user account with access to Microsoft's OAuth 2.0 Authorization Server.
- The victim interacts with the malicious pop-up browser window.
- OAuth 2.0 Authorization Server.
- A compromised system running the AUTHENTIC ANTICS malware.
- Connectivity to the internet.

## Post-Conditions:

- Installed malware persistence mechanisms
- New user accounts created
- Network traffic logs with suspicious connections
- Stolen credentials (logins and passwords)
- Compromised user accounts
- Process execution logs with malicious activity
- Exfiltrated sensitive data

- Altered system files
- Event log entries indicating unauthorized access or changes
- Modified system configurations
- Registry key modifications
- Email logs with unusual outgoing messages
- File transfers to external servers

## **MITRE Technique**

**ID:** T1528

**Name:** Steal application access token

**Description:** Adversaries can steal application access tokens as a means of acquiring credentials to access remote systems and resources.

**More info:** <https://attack.mitre.org/techniques/T1528/>

## **Attack Step a7**

=====

**Name:** Forced Authentication as used by the malware

**Description:** Forced authentication is implemented by the Authentic Antics malware through the creation of a deceptive login prompt. The malware operates within legitimate Outlook processes, monitoring threads and windows for specific class names and user names associated with Outlook to integrate the fake prompts seamlessly. A pop-up browser window mimicking a genuine Microsoft login page is generated to induce victims into entering their credentials. Upon entry, these sensitive details are captured by the malware. Additionally, attempts are made to acquire OAuth tokens linked to the victim's Microsoft account, granting access to associated services and data. This technique circumvents conventional security measures by exploiting the trust placed in legitimate Outlook operations.

## **Pre-Conditions:**

- The victim's account is configured to use ADAL authentication.
- Network connectivity to the target victim's system.
- The victim's system is running a Microsoft operating system.
- Access to the victim's email account credentials.
- The victim's account is not using a legacy single sign-on (SSO) mechanism.
- A compromised system with AUTHENTIC ANTICS malware installed.

## **Post-Conditions:**

- Stolen credentials (passwords, OAuth tokens)
- Altered system settings
- Compromised email accounts
- Presence of obfuscated code in memory
- Logs containing suspicious activity related to Outlook, authentication, and file access
- Modified registry keys in HKCU and HKLM
- Deleted or modified log files
- Network connections to C2 servers
- New files created with malicious code
- Potential for further malware infections and lateral movement within the network
- Data exfiltration from compromised accounts

- Unusual network traffic patterns

### ***MITRE Technique***

**ID:** T1187

**Name:** Forced authentication

**Description:** Adversaries may gather credential material by invoking or forcing a user to automatically provide authentication information through a mechanism in which they can intercept.

**More info:** <https://attack.mitre.org/techniques/T1187/>

# Milestone *m4*

## Attack Step *a8*

=====

**Name:** Exfiltration Over Web Service as used by the malware

**Description:** The malware, designated "Authentic Antics," facilitates data exfiltration via a web service by compromising victim Microsoft Outlook accounts through exploitation of the associated web API. Credential acquisition is achieved through deceptive login prompts designed to elicit Microsoft Office credentials (username/password) from users. Additionally, OAuth 2.0 tokens, granting extended access to cloud services such as Exchange Online, SharePoint, and OneDrive, are captured. Subsequent to credential and token acquisition, Authentic Antics utilizes these credentials to authenticate with the victim's Outlook account via the Outlook web API, enabling programmatic access to email functionality. Email forwarding from the victim's inbox to a designated attacker-controlled address is executed silently. This forwarding operation does not result in entries within the victim's "Sent" folder, thereby hindering detection efforts. Authentic Antics leverages legitimate Microsoft services and APIs for data exfiltration, circumventing traditional security measures through inconspicuous operation.

### Pre-Conditions:

- An active internet connection to send exfiltrated data.
- The malware has successfully compromised a victim's system.
- A compromised victim system with internet connectivity.
- The malware has obtained stolen credentials or access tokens.
- Access to the victim's email account and data.

### Post-Conditions:

- Compromised email accounts
- Altered Outlook settings
- Unusual email activity (sent emails, forwarding rules)
- Network traffic logs with suspicious connections
- System event logs indicating unauthorized access
- Obfuscated code in memory
- Presence of malicious DLLs or executables
- Exfiltrated data files
- Potential for further malicious activity
- Persistent access to victim systems
- Modified registry keys
- Web server logs showing unusual requests from compromised systems
- Data theft (credentials, sensitive information)

### *MITRE Technique*

**ID:** T1567

**Name:** Exfiltration over web service

**Description:** Adversaries may use an existing, legitimate external Web service to exfiltrate data rather than their primary command and control channel. Popular Web services acting as an exfiltration mechanism may give a significant amount of cover due to the likelihood that hosts within a network are already communicating with them prior to compromise. Firewall rules may also already exist to permit

traffic to these services.

**More info:** <https://attack.mitre.org/techniques/T1567/>